EburSeal

Le sceau invisible des diplômes ivoiriens

Recueil des besoins

Besoins fonctionnels et ingénierie des exigences de sécurité (SRE)

Projet	EburSeal — délivrance et vérification de diplômes infalsifiables (Côte d'Ivoire)
Équipe (binôme)	OUATTARA Yacouba · YEO Tanna Daouda
Formation	SUP'COM — 3e année cycle ingénieur, option CySeD
Module / encadrant	Sécurité Applicative — Dr. Ing. Mohamed-Becha Kaâniche
Approche SRE	SQUARE adapté (ossature) + cas d'abus / cas de sécurité + récits d'abus / de sécurité + arbres d'attaque et STRIDE
Contenu	29 besoins fonctionnels · 11 cas d'abus · 71 exigences de sécurité priorisées et tracées
Version / date	v1.0 — 08/11/2026 (document évolutif : voir § 11)

Historique des versions

Version	Date	Auteur(s)	Modifications
1.0	08/11/2026	O. Yacouba, Y. T. Daouda	Version initiale : SQUARE étapes 1 à 9, catalogue des exigences, traçabilité

Sommaire

1. Introduction 4
1.1 Objet du document . . . 4
1.2 Références . . . 4
1.3 Conventions . . . 4
2. Justification de l'approche SRE choisie 5
2.1 Ce que notre contexte exige d'une approche . . . 5
2.2 Évaluation des approches du cours . . . 5
2.3 Approches complémentaires citées dans l'énoncé . . . 6
2.4 Décision : SQUARE adapté comme ossature . . . 6
3. Besoins fonctionnels 7
4. SQUARE étapes 1–2 : définitions, actifs et objectifs 9
4.1 Étape 1 — Définitions communes . . . 9
4.2 Étape 2 — Actifs et besoins C-I-D . . . 10
4.3 Objectifs de sécurité . . . 10
5. SQUARE étape 3 : artefacts — la perspective de l'attaquant 11
5.1 Mal-acteurs . . . 11
5.2 Diagramme des cas d'utilisation, d'abus et de sécurité . . . 11
5.3 Fiches des cas d'abus . . . 11
5.4 Cas d'utilisation de sécurité . . . 15
5.5 Récits d'abus et récits de sécurité (backlog GitHub) . . . 16
5.6 Arbres d'attaque . . . 17
6. SQUARE étape 4 : évaluation des risques 19
6.1 Analyse STRIDE par composant . . . 19
6.2 Matrice des risques . . . 19
7. SQUARE étape 5 : techniques d'élicitation retenues 20
8. SQUARE étapes 6–7 : exigences de sécurité élicitées et catégorisées 21
8.1 Principes de rédaction . . . 21
8.2 Identification & authentification (AUT) — Ch. 4 . . . 21
8.3 Autorisation (contrôle d'accès) (AUZ) — Ch. 4 . . . 22
8.4 Confidentialité (CON) — Ch. 3 . . . 23
8.5 Intégrité & validation des données (INT) — Ch. 3 . . . 23
8.6 Non-répudiation (NRP) — Ch. 3–4 . . . 24
8.7 Sécurité des services de dissimulation (DIM) — Ch. 2–3 . . . 24
8.8 Informations privées (loi n° 2013-450, RGPD) (PRV) — Ch. 4 . . . 25
8.9 Journalisation, audit & détection d'intrusion (LOG) — Ch. 5 . . . 25
8.10 Gestion des erreurs & conditions exceptionnelles (ERR) — Ch. 5 . . . 26
8.11 Résilience & disponibilité (DIS) — Ch. 3 / 7 . . . 26
8.12 Tests de sécurité (TST) — Ch. 6 . . . 26
8.13 Déploiement & maintenance (DEP) — Ch. 7 . . . 27

9. SQUARE étape 8 : priorisation (AHP) 28

9.1 Critères et matrice de comparaison 28

9.2 Règle de triage et résultat 28

10. SQUARE étape 9 : inspection et traçabilité 29

10.1 Inspection des exigences 29

10.2 Matrice de traçabilité 29

10.3 Couverture de l'OWASP Top 10 2025 30

11. Gestion des exigences (évolution du recueil) 30

1. Introduction

1.1 Objet du document

Ce document recense les **besoins fonctionnels** d'EburSeal et ses **exigences de sécurité**, obtenues par une démarche d'ingénierie des exigences de sécurité (IES / *Security Requirements Engineering*, SRE). Il complète le cahier des charges, qui décrit le projet, son périmètre et son architecture.

Conformément à l'énoncé, il **justifie l'approche SRE choisie** (§ 2) et **recense en détail** les besoins de sécurité (§ 8). Conformément au cours, une exigence de sécurité est une exigence **non fonctionnelle** et **négative** (ce que le système **ne doit pas** permettre). Elle est donc rédigée **séparément** des besoins fonctionnels, pour être examinée et testée séparément.

1.2 Références

Réf.	Document
[COURS]	M.-B. Kaâniche, *Sécurité Applicative*, ch. 1 et 2 — SUP'COM, 2026
[ENONCE]	Énoncé de l'atelier : cahier des charges PWA/SPA Jakarta EE 11 — WildFly 42 / Java 25
[SQUARE]	N. Mead, T. Stehney, *Security Quality Requirements Engineering (SQUARE) Methodology*, CMU/SEI-2005-TR-009
[OWASP-T10]	OWASP Top 10 — édition 2025
[ASVS]	OWASP Application Security Verification Standard 5.0.0 (mai 2025) — niveau cible : **2**
[LOI-CI]	Loi n° 2013-450 du 19 juin 2013 relative à la protection des données à caractère personnel (Côte d'Ivoire) ; autorité de contrôle : ARTCI
[RGPD]	Règlement (UE) 2016/679 — référence de bonnes pratiques (titulaires de la diaspora, vérificateurs européens)
[RFC]	RFC 6238 (TOTP), RFC 7519 (JWT), RFC 8446 (TLS 1.3), RFC 8032 (Ed25519), RFC 9457 (Problem Details)

1.3 Conventions

Préfixe	Signification	Exemple
BF-<module>-nn	Besoin fonctionnel (MoSCoW : M = Must, S = Should, C = Could)	BF-EMI-02
A*n* / **OS-*n***	Actif à protéger / objectif de sécurité	A1, OS-1
CA-nn	Cas d'abus (point de vue de l'attaquant)	CA-03
CS-nn	Cas d'utilisation de sécurité, qui *mitigates* le cas d'abus de même numéro	CS-03
R-nn	Risque évalué (vraisemblance × impact)	R-03
SR-<cat>-nn	Exigence de sécurité, priorité P1 / P2 / P3 issue de l'AHP	SR-DIM-10

2. Justification de l'approche SRE choisie

2.1 Ce que notre contexte exige d'une approche

Le cours présente deux familles d'approches IES/SRE : les approches **dérivées** (cas d'abus, cas d'utilisation de sécurité, récits d'abus) et les approches **dédiées** (SQUARE, OCTAVE). L'énoncé y ajoute les arbres d'attaque, UMLsec/SecureUML et SERA. Nous avons d'abord fixé les critères imposés par notre situation :

Critère	Pourquoi il compte pour EburSeal
K1 — Recueillir le fonctionnel et le non fonctionnel	L'énoncé demande un document recensant les besoins **fonctionnels et SRE**
K2 — Supporter des exigences qui changent	L'énoncé prévoit que le recueil « pourra évoluer tout au long du cours »
K3 — Résoudre ambiguïtés et conflits	Plusieurs objectifs se contredisent (vérification publique ↔ vie privée, traçage ↔ minimisation)
K4 — Adopter la perspective de l'attaquant	Objectif fondamental de l'énoncé ; nos fraudeurs (faussaire, imposteur, agent corrompu) sont variés
K5 — Être traçable et testable	Suivi sur GitHub ; chaque exigence doit être vérifiée dans le code
K6 — Rester praticable par un binôme	Charge limitée ; intégration au backlog agile (issues, PR)
K7 — Fournir un niveau de sécurité élevé	Le service produit des **preuves** : une faille ruine la confiance dans tous les diplômes

2.2 Évaluation des approches du cours

Le tableau reprend les **valeurs des tableaux comparatifs du cours** (Comparaison des approches IES/SRE, 1 à 4) pour chacun de nos critères.

Critère (source : tableaux du cours)	Cas d'utilisation	Récits	SQUARE	OCTAVE
K1 — Exigences autres que sécurité	Non fonct. seulement	Non supporté	**Fonct. + non fonct.**	Non fonct. seulement
K2 — Support des exigences changeantes	Non supporté	Non supporté	**Modéré–Élevé**	Non supporté
K3 — Résolution des ambiguïtés	Faible	Faible	**Élevé**	Aucun
K3 — Prévention des conflits	Prévention définie	Non supporté	**Prévention définie**	Faible
K4 — Support de l'élicitation	**Élevé**	Modéré–Élevé	Faible–Modéré	Modéré–Élevé
K5 — Traçabilité	Faible	**Élevé**	Faible	Modéré
K5 — Base pour vérification / validation	Modéré	Faible	**Modéré-Élevé**	Modéré
K6 — Facilité pour un novice	**Facile**	**Facile**	Modéré	Difficile
K6 — Facilité de modification	**Facile**	**Facile**	Modéré	Difficile
K7 — Niveau de sécurité de la spécification	Modéré	Faible	**Modéré-Élevé**	Modéré
Cohérence de la spécification	Modéré	Faible	**Modéré-Élevé**	Faible

Lecture. Aucune approche ne satisfait seule tous les critères. **SQUARE** est la seule qui couvre K1, K2 et K3 (les trois demandes explicites de l'énoncé) et donne la spécification la plus sûre (K7). Ses faiblesses sont la **traçabilité** (K5) et le **support de l'élicitation** (K4), qui sont précisément les points forts des **récits** et des **cas d'abus**. OCTAVE est écartée : difficile à modifier, aucune résolution d'ambiguïté, pas de support des exigences changeantes, et orientée organisation plutôt que logiciel.

2.3 Approches complémentaires citées dans l'énoncé

Approche	Décision	Justification
Arbres d'attaque / modélisation des menaces (STRIDE)	**Retenue** (étapes 3–4)	Décompose les buts du fraudeur (K4) ; alimente l'évaluation des risques de SQUARE
Récits d'abus / récits de sécurité	**Retenue** (backlog)	Traçabilité élevée (K5) ; intégrés aux issues GitHub et à la « Definition of Done »
Cas d'abus / cas d'utilisation de sécurité	**Retenue** (étape 3)	Élicitation élevée (K4) ; c'est l'artefact « misuse cases » prévu par l'étape 3 de SQUARE
OCTAVE	Non retenue	Évaluation organisationnelle des risques ; trop lourde à modifier pour un recueil évolutif (K2, K6)
UMLsec / SecureUML	Non retenue (v1)	Ingénierie dirigée par les modèles, coûteuse en outillage pour un binôme ; les contraintes RBAC sont exprimées dans une matrice rôles × ressources
SERA	Non retenue	Analyse de risque par chaînes de missions (systèmes multi-organisations complexes) : surdimensionnée pour la v1

2.4 Décision : SQUARE adapté comme ossature

Nous adoptons **SQUARE comme processus** (ses 9 étapes structurent ce document) et plaçons dans ses étapes les approches dérivées, là où elles compensent ses faiblesses :



Figure 1 — Processus SQUARE adapté suivi dans ce document (§ 4 à § 10)

Faiblesse de SQUARE (cours)	Compensation retenue
Support de l'élicitation faible à modéré	Étape 3 : **cas d'abus** (élicitation élevée) + arbres d'attaque ; étape 5 : checklists OWASP ASVS / Top 10 2025
Traçabilité faible	**Récits d'abus / de sécurité** dans les issues GitHub + identifiants dans chaque commit + matrice CA → R → CS → SR → test (§ 10)
« Utile uniquement pour les grands projets »	SQUARE **allégé** : étapes 1–2 et 6–7 fusionnées dans des tableaux uniques ; référentiel unique qui régénère PDF et CSV
Spécification semi-formelle	Exigences **SMART** : seuils chiffrés, algorithmes nommés, méthode de vérification pour chacune

Synthèse de la justification — SQUARE est retenu car c'est la seule approche du cours qui recueille le fonctionnel et le non fonctionnel, supporte les exigences changeantes et résout les ambiguïtés. Ce sont les trois demandes explicites de l'énoncé. Ses deux faiblesses (élicitation, traçabilité) sont comblées par les cas d'abus et les récits, qui excellent sur ces critères.

3. Besoins fonctionnels

Comme le prévoit l'élicitation en IES (« analyser les exigences fonctionnelles du système »), les besoins fonctionnels sont établis en premier : ce sont eux que les cas d'abus menacent. Ce sont des exigences **positives** : ce que le système **doit** faire.

Module Socle

ID	Besoin	Description	Prio	Critère d'acceptation
BF-CPT-01	**Activer un compte**	Le titulaire active son compte depuis l'invitation envoyée par son établissement ; les vérificateurs créent un compte d'organisation soumis à validation.	M	Lien d'activation à usage unique valable 72 h ; compte vérificateur inactif tant qu'il n'est pas validé.
BF-CPT-02	**Se connecter / se déconnecter**	Authentification par e-mail + mot de passe, puis second facteur si activé ou obligatoire pour le rôle.	M	Après déconnexion, l'ancien jeton est refusé (401).
BF-CPT-03	**Gérer le second facteur**	Activer un TOTP (application d'authentification) et obtenir des codes de secours.	M	QR code d'enrôlement + 10 codes de secours à usage unique.
BF-CPT-04	**Réinitialiser le mot de passe**	Demande par e-mail, lien à usage unique.	M	Lien expiré après 15 min ou après première utilisation.
BF-CPT-05	**Gérer ses données personnelles**	Le titulaire consulte et exporte ses données, et peut fermer son compte (les diplômes restent au registre de l'établissement).	S	Export JSON + copies personnelles en ZIP ; fermeture effective sous 30 jours.

Module Établissement

ID	Besoin	Description	Prio	Critère d'acceptation
BF-ETB-01	**Inscrire un établissement**	Demande d'inscription d'un établissement (pièces justificatives) ; validation par l'administrateur, qui génère ses clés.	M	Aucune émission possible avant validation ; clés de filigrane et de signature propres à l'établissement.
BF-ETB-02	**Gérer les agents**	Le responsable émetteur invite, suspend et retire les agents de son établissement.	M	Un agent n'est rattaché qu'à un seul établissement.

Module Émission

ID	Besoin	Description	Prio	Critère d'acceptation
BF-EMI-01	**Préparer un diplôme**	L'agent saisit les données officielles (titulaire, date de naissance, intitulé, spécialité, mention, session, numéro) et dépose le visuel du diplôme (PDF d'une page ou PNG).	M	Diplôme créé au statut « en attente de validation ».
BF-EMI-02	**Valider et émettre**	Le responsable relit et valide ; la plateforme applique automatiquement le **filigrane**, le **sceau caché** et produit le **certificat d'émission** ; le titulaire est invité.	M	Le valideur est différent du préparateur ; diplôme émis en PDF et PNG en moins de 15 s.
BF-EMI-03	**Émettre par lot**	Import d'un fichier CSV + visuels pour une promotion entière, puis validation groupée.	S	Lot de 200 diplômes traité en tâche de fond, avec rapport d'erreurs par ligne.
BF-EMI-04	**Révoquer un diplôme**	Le responsable révoque un diplôme (erreur, fraude) avec motif ; une réémission corrigée est possible.	M	Toute vérification ultérieure affiche « révoqué » avec la date.

Module Watermarking

ID	Besoin	Description	Prio	Critère d'acceptation
BF-WM-01	**Filigrane de l'établissement**	Filigrane invisible, robuste, lié à la clé secrète de l'établissement, inséré dans le domaine DCT de chaque diplôme émis.	M	Invisible (PSNR ≥ 40 dB) ; détecté après JPEG qualité 75 et redimensionnement à 75 %.
BF-WM-02	**Mention visible**	Mention visible discrète « Vérifiable sur EburSeal » et numéro court du diplôme.	C	Position et taille paramétrables par l'établissement.
BF-WM-03	**Certificat d'émission**	Certificat signé par l'établissement : empreinte SHA-256 du document, données officielles, date d'émission.	M	Certificat JSON + PDF vérifiable avec la clé publique de l'établissement.

Module Stéganographie

ID	Besoin	Description	Prio	Critère d'acceptation
BF-STG-01	**Sceau caché**	Les données officielles signées sont **dissimulées dans le document lui-même** (domaine DCT, positions secrètes, code correcteur).	M	Sceau extrait intact après JPEG qualité 75 ; aucune trace visible.
BF-STG-02	**Comparer affiché / caché**	À la vérification, les données extraites du sceau sont affichées **à côté** du document pour que le vérificateur compare.	M	Écran « données officielles » + aperçu du document côte à côte.
BF-STG-03	**Vérification autoportée**	Le document se vérifie même si le diplôme n'est pas trouvé au registre (instance partenaire, base indisponible), grâce au sceau signé.	S	Résultat « authentique (vérification par sceau) » sans accès au registre.

Module Fingerprinting

ID	Besoin	Description	Prio	Critère d'acceptation
BF-FP-01	**Partager une copie traçable**	Le titulaire génère une copie pour un destinataire (organisation inscrite ou nom libre), une finalité et une durée de validité.	M	Chaque copie porte un code d'empreinte unique ; ≤ 30 partages actifs par diplôme.
BF-FP-02	**Copie personnelle**	Tout téléchargement par le titulaire produit une copie empreintée à son nom ; l'original non marqué n'est jamais téléchargeable.	M	Aucun fichier sans empreinte ne sort de la plateforme.
BF-FP-03	**Détecter une copie hors contexte**	Si une copie est vérifiée par une organisation qui n'en est pas le destinataire, ou après expiration, la vérification l'indique et le titulaire est alerté.	M	Alerte « copie émise pour un autre destinataire » + notification au titulaire.
BF-FP-04	**Gérer ses partages**	Lister, révoquer un partage, consulter l'historique des vérifications de ses copies.	S	Une copie révoquée est signalée comme telle à toute vérification.

Module Vérification

ID	Besoin	Description	Prio	Critère d'acceptation
BF-VER-01	**Vérification publique**	Déposer un fichier (PDF, PNG, JPEG) et obtenir : établissement émetteur, authenticité, données officielles, statut.	M	Verdict « authentique / non authentique / indéterminé » en moins de 10 s.
BF-VER-02	**Espace vérificateur**	L'organisation reçoit les copies qui lui sont partagées et vérifie tout document avec contrôle du destinataire.	M	Boîte de réception des partages ; contrôle automatique « copie destinée à mon organisation ».
BF-VER-03	**Rapport de vérification**	Télécharger un rapport PDF signé de la vérification (date, résultat, identifiant de copie).	S	Rapport vérifiable avec la clé publique de la plateforme.

Module Administration

ID	Besoin	Description	Prio	Critère d'acceptation
BF-ADM-01	**Gérer la plateforme**	Valider établissements et vérificateurs, suspendre des comptes, attribuer les rôles plateforme.	M	Toute action d'administration est journalisée et exige le MFA.
BF-ADM-02	**Gérer les quotas**	Quotas d'émission par établissement et de vérifications par vérificateur.	S	Dépassement → refus explicite (429) et événement journalisé.
BF-ADM-03	**Consulter l'audit**	L'auditeur consulte et filtre journaux et alertes, et l'état de la chaîne d'intégrité.	M	Recherche par acteur, type d'événement, période ; export CSV.

Module PWA

ID	Besoin	Description	Prio	Critère d'acceptation
BF-PWA-01	**Application installable**	Manifest, icônes, Service Worker ; vérification utilisable sur mobile ; page hors ligne informative.	M	PWA installable ; aucune donnée privée disponible hors ligne.
BF-PWA-02	**Notifications**	Notification dans l'application lors d'une vérification de ses copies ou d'une alerte.	C	Badge de compteur sur le tableau de bord du titulaire.

Répartition MoSCoW : 21 Must, 6 Should, 2 Could. Les besoins « Could » sont abandonnés en premier en cas de retard ; ils n'ont aucun impact sur la sécurité.

4. SQUARE étapes 1–2 : définitions, actifs et objectifs

4.1 Étape 1 — Définitions communes

La première étape consiste à s'accorder sur le vocabulaire, pour que chaque exigence ait un sens unique. Les définitions génériques s'appuient sur l'ISO/IEC 27000 et l'IEEE ; les définitions métier sont propres à EburSeal.

Terme	Définition retenue
Actif	Élément ayant de la valeur pour les titulaires, les établissements ou la plateforme, et qui doit être protégé (§ 4.2)
Menace / vulnérabilité / risque	Menace : cause potentielle d'un incident ; vulnérabilité : faiblesse exploitable ; risque : combinaison de la vraisemblance d'un scénario et de son impact
Mal-acteur	Acteur qui cherche à abuser du système (cas d'abus) ; 6 profils au § 5.1
Diplôme émis	Document produit par la plateforme après double validation, portant filigrane et sceau, accompagné d'un certificat d'émission
Copie	Fichier dérivé d'un diplôme émis, portant en plus une empreinte propre à son destinataire (ou au titulaire)
Registre	Base des diplômes émis et de leur statut (émis, révoqué), tenue par la plateforme pour le compte des établissements
Filigrane (watermark)	Marque invisible et robuste, identique sur tous les diplômes d'un établissement, générée avec la clé secrète de cet établissement
Sceau caché	Données officielles du diplôme, signées puis chiffrées, dissimulées par stéganographie dans le document
Empreinte (fingerprint)	Code aléatoire de 64 bits, différent pour chaque copie, dissimulé dans la copie
DCT	Transformée en cosinus discrète par blocs 8×8 (utilisée par JPEG) : domaine d'insertion des trois couches
PSNR	Rapport signal/bruit de crête (dB) entre le visuel déposé et le diplôme émis ; mesure l'imperceptibilité des marques
Robustesse	Capacité d'une marque à rester lisible après transformation (recompression JPEG, redimensionnement)
Verdict	Résultat d'une vérification : « authentique », « non authentique » ou « indéterminé » (§ 8, SR-DIM-05)
Copie hors contexte	Copie vérifiée par une organisation qui n'en est pas le destinataire, ou après expiration ou révocation du partage
Collusion	Plusieurs destinataires comparent leurs copies pour effacer l'empreinte (hors périmètre v1)
Double validation	Principe des « quatre yeux » : le valideur d'une émission est une personne différente du préparateur

4.2 Étape 2 — Actifs et besoins C-I-D

Chaque actif est coté de 1 (faible) à 4 (critique) sur la confidentialité (C), l'intégrité (I) et la disponibilité (D). Pour EburSeal, l'**intégrité** domine : le service vend de la confiance, et une seule fausse preuve suffit à la ruiner.

ID	Actif	Description	C	I	D
A1	**Registre des diplômes**	Données officielles émises par les établissements et leur statut (émis, révoqué)	3	4	3
A2	**Clés cryptographiques**	Clés de filigrane et de signature des établissements, clé de position du sceau, clé maître	4	4	3
A3	**Documents diplômes**	Visuels déposés, diplômes émis, copies empreintées	3	4	3
A4	**Identifiants et sessions**	Mots de passe hachés, secrets TOTP, jetons	4	4	3
A5	**Certificats d'émission**	Preuves signées de l'émission et de la révocation	2	4	4
A6	**Table des partages**	Correspondance code d'empreinte ↔ titulaire, destinataire, finalité	4	4	2
A7	**Journaux d'audit**	Traces des émissions, validations, révocations, vérifications	3	4	3
A8	**Données personnelles des titulaires**	Nom, prénoms, date de naissance, parcours, historique des vérifications	4	3	2
A9	**Service de vérification**	Disponibilité de la vérification, en particulier en période de recrutement	1	3	4

4.3 Objectifs de sécurité

ID	Objectif de sécurité	Actifs	Propriété
OS-1	Un document ne peut être déclaré « authentique » que s'il a réellement été émis par l'établissement indiqué	A1, A2, A5	I
OS-2	Toute modification du contenu d'un diplôme émis est détectée	A3, A5	I
OS-3	Une copie présentée hors de son contexte est signalée, sans jamais accuser à tort	A6, A3	I
OS-4	Aucun diplôme ne peut être émis par une seule personne, ni hors de son établissement	A1, A4	I
OS-5	Les comptes, en particulier ceux des émetteurs, résistent à la prise de contrôle	A4	C, I
OS-6	Les données personnelles des titulaires ne sont accessibles qu'à partir du document lui-même ou par les ayants droit	A8, A6	C
OS-7	Toute émission, révocation et vérification est imputable, et toute altération des traces est détectée	A7, A5	I
OS-8	Le service de vérification reste disponible, y compris en période de recrutement	A9	D

5. SQUARE étape 3 : artefacts — la perspective de l'attaquant

5.1 Mal-acteurs

Mal-acteur	Profil et moyens
Faussaire	Fabrique de toutes pièces un diplôme d'apparence officielle (logiciel de retouche, imprimeur)
Titulaire fraudeur	Possède un vrai diplôme et en modifie le contenu (mention, intitulé, année)
Imposteur	Présente comme le sien le diplôme authentique d'une autre personne (copie récupérée, homonyme)
Agent corrompu ou compromis	Agent émetteur (ou compte d'agent volé) qui tente d'émettre un « vrai faux » diplôme de complaisance
Destinataire indélicat	Vérificateur qui laisse fuiter ou revend les dossiers de candidature reçus
Attaquant externe	Anonyme sur Internet : force brute, injection, collecte massive de données, déni de service

5.2 Diagramme des cas d'utilisation, d'abus et de sécurité

Le diagramme suit la notation du cours : les cas d'abus (en noir) « **threatens** » les cas d'utilisation qu'ils menacent ; les cas d'utilisation de sécurité (en vert) « **mitigates** » les cas d'abus et sont « **include** » par les cas d'utilisation qu'ils protègent. Les cas d'abus CA-07 à CA-11, transverses, sont détaillés dans les fiches.

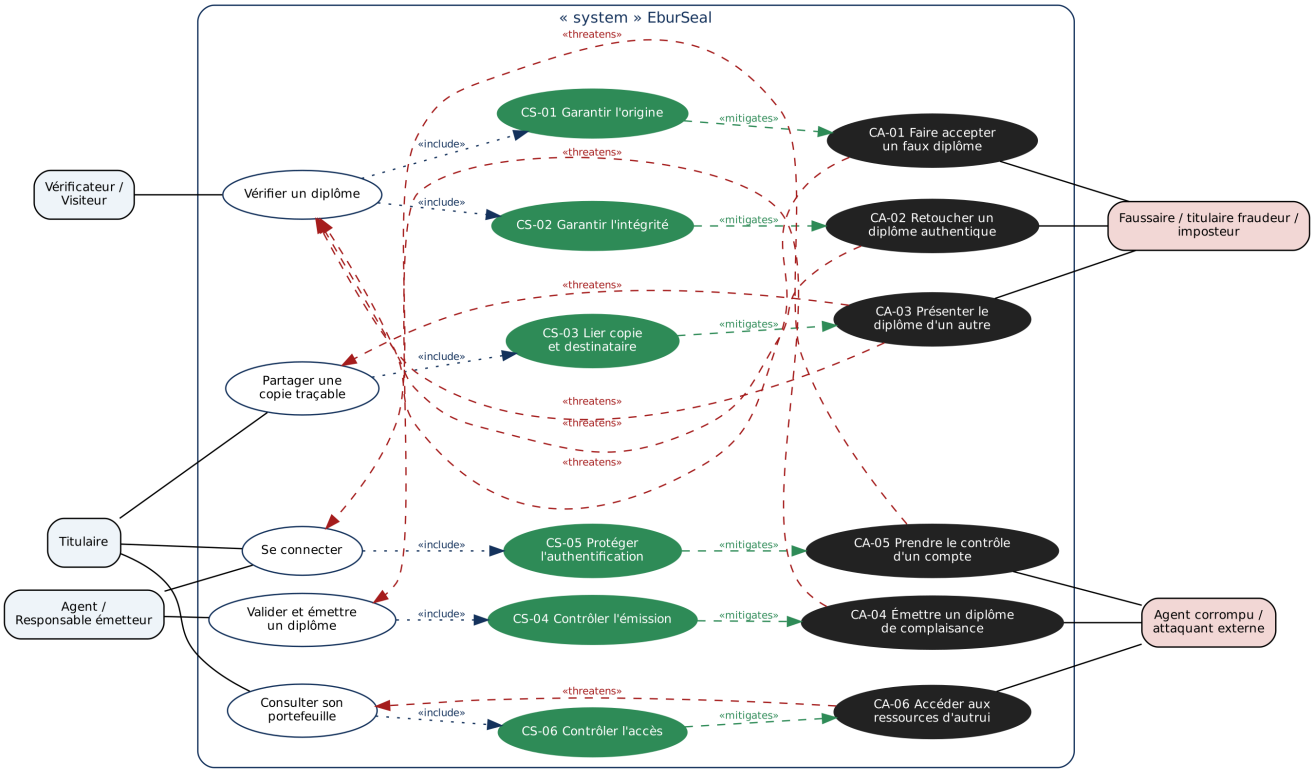


Figure 2 — Cas d'utilisation, cas d'abus et cas de sécurité principaux

5.3 Fiches des cas d'abus

Chaque fiche reprend le **modèle de fiche de cas d'abus du cours**. Les 8 étapes du cours ont été suivies : brainstorming, analyse des cas d'utilisation du § 3, point de vue de l'adversaire, identification des mal-acteurs, définition des cas d'abus, recherche d'au moins un cas d'abus par cas d'utilisation sensible, puis vérification de la granularité, de l'exhaustivité et de la minimalité (aucun cas d'abus n'en duplique un autre).

CA-01 — Faire accepter un faux diplôme

Priorité / sophistication	Élevée / Moyenne
Mal-acteur(s) · niveau d'accès	Faussaire · Aucun
Point d'entrée	Document présenté à un recruteur, POST /api/verify
Attributs de sécurité affectés	I
Description	Le faussaire fabrique un diplôme imitant parfaitement le modèle d'un établissement (logo, signatures scannées, mise en page) et espère qu'il passera la vérification ou que le recruteur ne vérifiera pas.
Pré-condition / post-condition	**Pré :** Modèle visuel de l'établissement disponible (diplômes publiés sur les réseaux sociaux). **Post (si succès) :** Recrutement ou admission sur la base d'un diplôme inexistant.
Cas d'utilisation menacés	Vérifier un diplôme
Recommandation architecturale	Filigrane invisible lié à une clé secrète par établissement ; certificat signé ; verdict « non authentique » en l'absence de filigrane valide.
Cas de sécurité « mitigates »	**CS-01 — Garantir l'origine du diplôme**

CA-02 — Retoucher un diplôme authentique

Priorité / sophistication	Élevée / Faible
Mal-acteur(s) · niveau d'accès	Titulaire fraudeur · Titulaire (possède une copie)
Point d'entrée	Copie personnelle téléchargée
Attributs de sécurité affectés	I
Description	Le titulaire modifie sur sa copie la mention (Passable → Bien), le niveau (Licence → Master) ou l'année, en conservant le reste du document intact pour garder le filigrane.
Pré-condition / post-condition	**Pré :** Disposer d'une copie authentique. **Post (si succès) :** Avantage indu (poste, salaire, admission) obtenu avec un diplôme falsifié.
Cas d'utilisation menacés	Vérifier un diplôme, Télécharger sa copie
Recommandation architecturale	Sceau caché signé contenant les données officielles ; affichage côte à côte affiché / officiel ; contrôle au registre.
Cas de sécurité « mitigates »	**CS-02 — Garantir l'intégrité du contenu**

CA-03 — Présenter le diplôme d'un autre

Priorité / sophistication	Élevée / Faible
Mal-acteur(s) · niveau d'accès	Imposteur, Destinataire indélicat · Aucun (copie récupérée)
Point d'entrée	Copie partagée ayant fuité, POST /api/verify
Attributs de sécurité affectés	I, C
Description	L'imposteur récupère une copie authentique (dossier qui a fuité, homonyme) et la présente comme la sienne. Le diplôme est vrai ; c'est le porteur qui ment.
Pré-condition / post-condition	**Pré :** Une copie a circulé en dehors de son destinataire. **Post (si succès) :** Usurpation de l'identité académique d'autrui.
Cas d'utilisation menacés	Partager une copie, Vérifier un diplôme
Recommandation architecturale	Copie empreintée par destinataire ; contrôle « copie destinée à mon organisation » ; alerte au titulaire ; expiration des partages.
Cas de sécurité « mitigates »	**CS-03 — Lier chaque copie à son destinataire**

CA-04 — Émettre un diplôme de complaisance

Priorité / sophistication	Élevée / Moyenne
Mal-acteur(s) · niveau d'accès	Agent corrompu ou compromis · Agent émetteur
Point d'entrée	POST /api/diplomas, /api/diplomas/{id}/validate
Attributs de sécurité affectés	I
Description	Un agent crée et fait émettre un diplôme pour une personne qui ne l'a pas obtenu (« vrai faux »), ou un attaquant utilise le compte volé d'un agent.
Pré-condition / post-condition	**Pré :** Accès à un compte d'agent émetteur. **Post (si succès) :** Diplôme cryptographiquement « authentique » mais frauduleux ; atteinte grave à la confiance dans la plateforme.
Cas d'utilisation menacés	Préparer un diplôme, Valider et émettre
Recommandation architecturale	Double validation par un responsable distinct, MFA obligatoire pour les émetteurs, journal d'audit chaîné, révocation, alertes sur volumes anormaux.
Cas de sécurité « mitigates »	**CS-04 — Contrôler et tracer l'émission**

CA-05 — Prendre le contrôle d'un compte

Priorité / sophistication	Élevée / Faible
Mal-acteur(s) · niveau d'accès	Attaquant externe · Aucun
Point d'entrée	POST /api/auth/login, /api/auth/reset, stockage du navigateur
Attributs de sécurité affectés	C, I
Description	Force brute ou réutilisation de mots de passe volés (credential stuffing), énumération des comptes via les messages d'erreur, ou vol de jeton dans le navigateur (XSS, poste partagé).
Pré-condition / post-condition	**Pré :** Formulaire de connexion exposé. **Post (si succès) :** Compte de titulaire (partages), d'agent (émission) ou de vérificateur (dossiers) usurpé.
Cas d'utilisation menacés	Se connecter
Recommandation architecturale	Limitation de débit, temporisation, mots de passe longs vérifiés contre les fuites, MFA, messages génériques, jetons en mémoire.
Cas de sécurité « mitigates »	**CS-05 — Protéger l'authentification et les sessions**

CA-06 — Accéder aux ressources d'autrui (IDOR)

Priorité / sophistication	Élevée / Faible
Mal-acteur(s) · niveau d'accès	Utilisateur malveillant (tout rôle) · Utilisateur authentifié
Point d'entrée	GET /api/diplomas/{id}, /api/shares/{id}, /api/inbox/{id}
Attributs de sécurité affectés	C, I
Description	Modification d'un identifiant dans l'URL pour lire le diplôme d'un autre titulaire, la liste de ses partages, ou les dossiers reçus par une autre organisation ; un agent tente d'agir sur un autre établissement.
Pré-condition / post-condition	**Pré :** Posséder un compte valide. **Post (si succès) :** Fuite de données personnelles et de dossiers ; émission pour un autre établissement.
Cas d'utilisation menacés	Consulter son portefeuille, Gérer ses partages, Espace vérificateur
Recommandation architecturale	Contrôle d'appartenance et de rattachement à l'établissement côté serveur, refus par défaut, identifiants non prédictibles.
Cas de sécurité « mitigates »	**CS-06 — Contrôler l'accès à chaque ressource**

CA-07 — Neutraliser les marques ou abuser de la vérification

Priorité / sophistication	Moyenne / Élevée
Mal-acteur(s) · niveau d'accès	Faussaire, Imposteur · Visiteur
Point d'entrée	POST /api/verify, copie authentique
Attributs de sécurité affectés	I
Description	L'attaquant transforme une copie (recompression, recadrage, bruit) et interroge la vérification en boucle pour apprendre quand l'empreinte ou le filigrane disparaît (attaque par oracle), afin d'obtenir une copie « propre » ou un verdict ambigu.
Pré-condition / post-condition	**Pré :** Disposer d'une copie authentique. **Post (si succès) :** Copie dont l'empreinte est effacée (usurpation non détectée) ou verdict trompeur.
Cas d'utilisation menacés	Vérification publique
Recommandation architecturale	Marques robustes et redondantes, verdict sans score, limitation de débit, « indéterminé » jamais présenté comme « authentique ».
Cas de sécurité « mitigates »	**CS-07 — Rendre la vérification non exploitable**

CA-08 — Injecter du code ou déposer un fichier piégé

Priorité / sophistication	Élevée / Moyenne
Mal-acteur(s) · niveau d'accès	Utilisateur malveillant, Attaquant externe · Visiteur ou authentifié
Point d'entrée	Dépôt de visuel, POST /api/verify, champs texte (nom, motif, finalité)
Attributs de sécurité affectés	C, I, D
Description	Dépôt d'un PDF contenant du JavaScript ou des fichiers embarqués, d'une image « bombe de décompression », d'un fichier polyglotte, ou saisie de <script> dans un champ réaffiché ; injection JPQL.
Pré-condition / post-condition	**Pré :** Fonction de dépôt ou champ texte accessible. **Post (si succès) :** Exécution de code chez d'autres utilisateurs, saturation du serveur, fuite de données.
Cas d'utilisation menacés	Préparer un diplôme, Vérification publique
Recommandation architecturale	Rastérisation des PDF (aucun contenu actif conservé), signatures binaires, limites de taille/dimensions/pages, ré-encodage, encodage des sorties, CSP, requêtes paramétrées.
Cas de sécurité « mitigates »	**CS-08 — Valider et neutraliser les entrées**

CA-09 — Collecter des données personnelles en masse

Priorité / sophistication	Moyenne / Faible
Mal-acteur(s) · niveau d'accès	Attaquant externe · Visiteur
Point d'entrée	POST /api/verify, éventuelle recherche par numéro
Attributs de sécurité affectés	C
Description	L'attaquant tente d'énumérer les numéros de diplôme ou d'interroger le service pour constituer une base de noms, dates de naissance et parcours (revente, hameçonnage ciblé, usurpation).
Pré-condition / post-condition	**Pré :** Service de vérification public. **Post (si succès) :** Fuite massive de données personnelles (atteinte à la loi n° 2013-450).
Cas d'utilisation menacés	Vérification publique
Recommandation architecturale	Vérification uniquement à partir du document lui-même (aucune recherche par nom ou numéro), limitation de débit, minimisation des données affichées.
Cas de sécurité « mitigates »	**CS-09 — Protéger les données des titulaires**

CA-10 — Nier une émission ou effacer ses traces

Priorité / sophistication	Moyenne / Moyenne
Mal-acteur(s) · niveau d'accès	Agent corrompu, Administrateur malveillant · Agent, responsable ou administrateur
Point d'entrée	Journaux, base de données
Attributs de sécurité affectés	I
Description	Un responsable nie avoir validé un diplôme de complaisance ; un administrateur supprime des lignes de journal ou réactive en base un diplôme révoqué.
Pré-condition / post-condition	**Pré :** Journalisation incomplète ou modifiable. **Post (si succès) :** Impossible d'établir les responsabilités ; fraude non sanctionnée.
Cas d'utilisation menacés	Valider et émettre, Révoquer, Consulter l'audit
Recommandation architecturale	Signatures des émissions et révocations, journal chaîné par hachage, séparation administrateur / auditeur / émetteur, horloge synchronisée.
Cas de sécurité « mitigates »	**CS-10 — Assurer la non-répudiation et l'audit**

CA-11 — Rendre la vérification indisponible

Priorité / sophistication	Moyenne / Faible
Mal-acteur(s) · niveau d'accès	Attaquant externe · Aucun
Point d'entrée	POST /api/verify, émission par lot
Attributs de sécurité affectés	D
Description	Rafales de vérifications coûteuses (extraction DCT) ou de lots d'émission géants pour saturer le service, par exemple en pleine campagne de recrutement.
Pré-condition / post-condition	**Pré :** Endpoints coûteux exposés. **Post (si succès) :** Recruteurs incapables de vérifier ; perte de confiance dans le service.
Cas d'utilisation menacés	Vérification publique, Émettre par lot
Recommandation architecturale	Quotas, limitation de débit, traitements asynchrones bornés, délais maximaux, supervision.
Cas de sécurité « mitigates »	**CS-11 — Préserver la disponibilité**

5.4 Cas d'utilisation de sécurité

Selon le cours, un cas d'utilisation de sécurité est **dérivé d'un cas d'abus** et fixe les exigences qui le contrent. Il décrit **ce qui doit être garanti**, pas le mécanisme (qui apparaît dans les exigences SR).

CS	Nom	« mitigates »	Ce qui est garanti	Exigences SR
CS-01	**Garantir l'origine du diplôme**	CA-01	Le système garantit qu'un document n'est déclaré authentique que s'il porte la marque, impossible à imiter, de l'établissement qui l'a émis.	CON-03, NRP-01, DIM-01, DIM-02, DIM-04, DIM-05, ERR-02
CS-02	**Garantir l'intégrité du contenu**	CA-02	Le système garantit que toute différence entre le contenu affiché et le contenu officiellement émis est rendue visible au vérificateur.	CON-04, DIM-01, DIM-03, DIM-04, DIM-05
CS-03	**Lier chaque copie à son destinataire**	CA-03	Le système garantit que chaque copie est liée à un destinataire, et qu'une présentation hors contexte est signalée au vérificateur et au titulaire.	CON-03, NRP-04, DIM-06, DIM-07, DIM-08, DIM-10
CS-04	**Contrôler et tracer l'émission**	CA-04	Le système garantit qu'aucune personne seule ne peut émettre un diplôme, et que toute émission est imputable.	AUT-03, AUT-08, AUZ-03, AUZ-04, AUZ-05, AUZ-07, NRP-02, LOG-01, LOG-03
CS-05	**Protéger l'authentification et les sessions**	CA-05	Le système garantit qu'une identité ne peut être usurpée par essais répétés ou par vol de session.	AUT-01, AUT-02, AUT-03, AUT-04, AUT-05, AUT-06, AUT-07, AUT-08, AUT-09, CON-01, CON-05, INT-05, INT-06, LOG-03, DEP-03

CS	Nom	« mitigates »	Ce qui est garanti	Exigences SR
CS-06	**Contrôler l'accès à chaque ressource**	CA-06	Le système garantit que chaque ressource n'est servie qu'à ses ayants droit, et chaque action limitée à l'établissement de son auteur.	AUZ-01, AUZ-02, AUZ-04, AUZ-06, CON-02, LOG-01, LOG-03, ERR-02
CS-07	**Rendre la vérification non exploitable**	CA-07	Le système garantit que la vérification ne donne aucune information exploitable pour neutraliser les marques.	DIM-01, DIM-04, DIM-05, DIM-06, DIM-09, ERR-02, TST-06
CS-08	**Valider et neutraliser les entrées**	CA-08	Le système garantit qu'aucun contenu déposé ou saisi ne peut être interprété comme du code.	INT-01, INT-02, INT-03, INT-04, INT-05, ERR-01, ERR-03, DIS-03, DEP-03
CS-09	**Protéger les données des titulaires**	CA-09	Le système garantit que les données d'un titulaire ne peuvent être obtenues sans disposer du document.	AUT-05, CON-04, DIM-08, DIM-09, PRV-02, PRV-03
CS-10	**Assurer la non-répudiation et l'audit**	CA-10	Le système garantit que toute émission, révocation et vérification est prouvable, et que toute altération des traces est détectée.	AUZ-05, NRP-01, NRP-02, NRP-03, NRP-04, NRP-05, LOG-01, LOG-02, LOG-04
CS-11	**Préserver la disponibilité**	CA-11	Le système garantit que la consommation de ressources d'un acteur est bornée et n'affecte pas les autres.	AUZ-07, INT-01, ERR-03, DIS-01, DIS-02, DIS-03, DIS-05

Comparaison cas d'abus / cas de sécurité (rappel du cours, appliqué à EburSeal)

Critère	Cas d'abus (CA)	Cas d'utilisation de sécurité (CS)
Utilisation	Spécifier les menaces	Spécifier les exigences de sécurité
Critère d'évaluation	Réussite du fraudeur (post-condition « si succès »)	Réussite des mesures (test SR-TST-04 démontrant l'échec de l'attaque)
Créé par / pris en charge par	Binôme en rôle « équipe sécurité »	Créé par l'équipe sécurité, pris en charge par l'équipe des exigences (même binôme, revue croisée)
Acteur	Mal-acteur (§ 5.1)	Utilisateur légitime / système
Piloté par	Analyse des menaces (STRIDE, arbres d'attaque)	Cas d'abus

5.5 Récits d'abus et récits de sécurité (backlog GitHub)

Chaque cas d'abus est réécrit en **récit d'abus** (« En tant que <mal-acteur>, je peux … ») et en **récit de sécurité** (« En tant que <acteur>, je veux … »). Ces récits deviennent des issues GitHub (modèles abuse-story et security-story du dépôt) : la sécurité entre dans le backlog et dans la « Definition of Done ».

CA	Récit d'abus	Récit de sécurité	Exigences
CA-01	En tant que faussaire, je peux reproduire le modèle d'un diplôme de l'ESATIC pour me faire recruter.	En tant que recruteur, je veux savoir en quelques secondes si un diplôme a vraiment été émis par l'établissement indiqué.	SR-DIM-02/05, SR-NRP-01
CA-02	En tant que titulaire fraudeur, je peux changer « Passable » en « Bien » sur ma copie.	En tant que vérificateur, je veux voir les données officielles à côté du document pour repérer toute retouche.	SR-DIM-03/05, SR-CON-04
CA-03	En tant qu'imposteur, je peux présenter le diplôme d'un homonyme récupéré dans un dossier qui a fuité.	En tant que titulaire, je veux être alerté si une copie que j'ai partagée est présentée ailleurs.	SR-DIM-06/07/10
CA-04	En tant qu'agent corrompu, je peux émettre un diplôme pour quelqu'un qui n'a pas réussi.	En tant que responsable d'établissement, je veux qu'aucun diplôme ne soit émis sans ma validation, et que tout soit tracé.	SR-AUZ-03, SR-AUT-03, SR-LOG-03
CA-05	En tant qu'attaquant, je peux tester des milliers de mots de passe sur le compte d'un agent.	En tant qu'agent, je veux que mon compte soit protégé par un second facteur et contre la force brute.	SR-AUT-01/03/04
CA-06	En tant qu'utilisateur malveillant, je peux changer l'identifiant dans /api/shares/{id} pour voir les partages d'un autre.	En tant que titulaire, je veux que personne d'autre que moi ne voie mes diplômes et mes partages.	SR-AUZ-01/02
CA-07	En tant que faussaire, je peux interroger la vérification en boucle pour savoir quand l'empreinte disparaît.	En tant qu'exploitant, je veux une vérification qui ne renseigne pas l'attaquant.	SR-DIM-09, SR-ERR-02

CA	Récit d'abus	Récit de sécurité	Exigences
CA-08	En tant qu'attaquant, je peux déposer un PDF contenant du JavaScript pour attaquer les vérificateurs.	En tant que vérificateur, je veux que tout document affiché soit inoffensif.	SR-INT-01/02/05
CA-09	En tant qu'attaquant, je peux énumérer les numéros de diplôme pour récupérer noms et dates de naissance.	En tant que titulaire, je veux que mes données ne soient jamais consultables sans le document.	SR-PRV-02, SR-DIM-08/09
CA-10	En tant qu'administrateur malveillant, je peux réactiver en base un diplôme révoqué et effacer la trace.	En tant qu'auditeur, je veux détecter toute altération des émissions, révocations et journaux.	SR-NRP-02/03, SR-AUZ-05
CA-11	En tant qu'attaquant, je peux saturer la vérification en pleine campagne de recrutement.	En tant que recruteur, je veux que la vérification reste disponible.	SR-DIS-01/02, SR-AUZ-07

5.6 Arbres d'attaque

Les arbres d'attaque décomposent un **but du fraudeur** en sous-buts. Un nœud « OU » est atteint si l'une des branches réussit ; un nœud « ET » exige toutes ses branches. Les feuilles vertes sont couvertes par une exigence ; les feuilles jaunes sont des risques résiduels assumés.

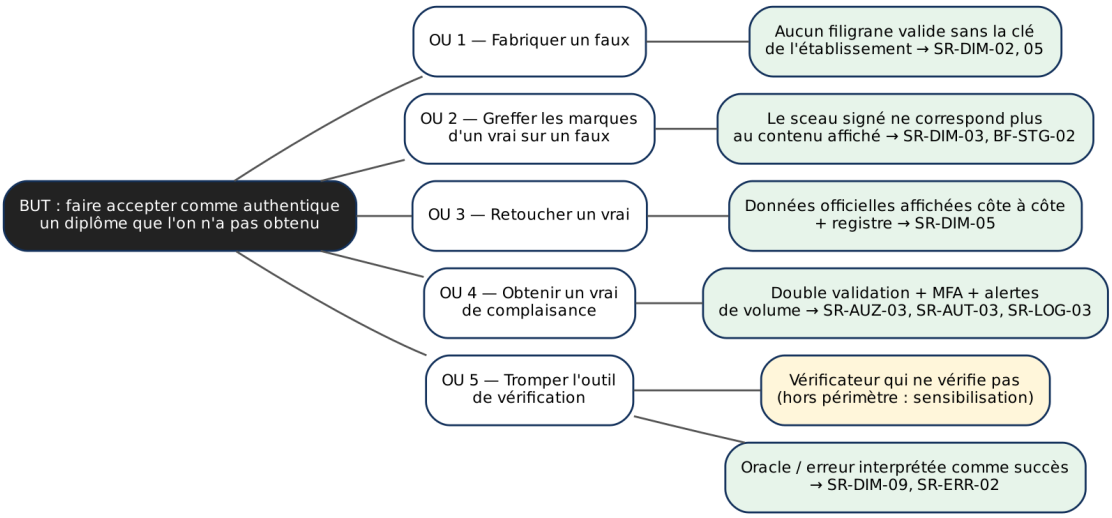


Figure 3 — Arbre d'attaque : faire accepter un diplôme non obtenu (objectifs OS-1, OS-2, OS-4)

Enseignement : la branche la plus dangereuse est l'**OU 4**. Un diplôme de complaisance est cryptographiquement parfait, et aucune marque ne peut le détecter. Seuls les contrôles organisationnels inscrits dans l'application (double validation, MFA des émetteurs, alertes de volume, audit chaîné) le rendent difficile et traçable.

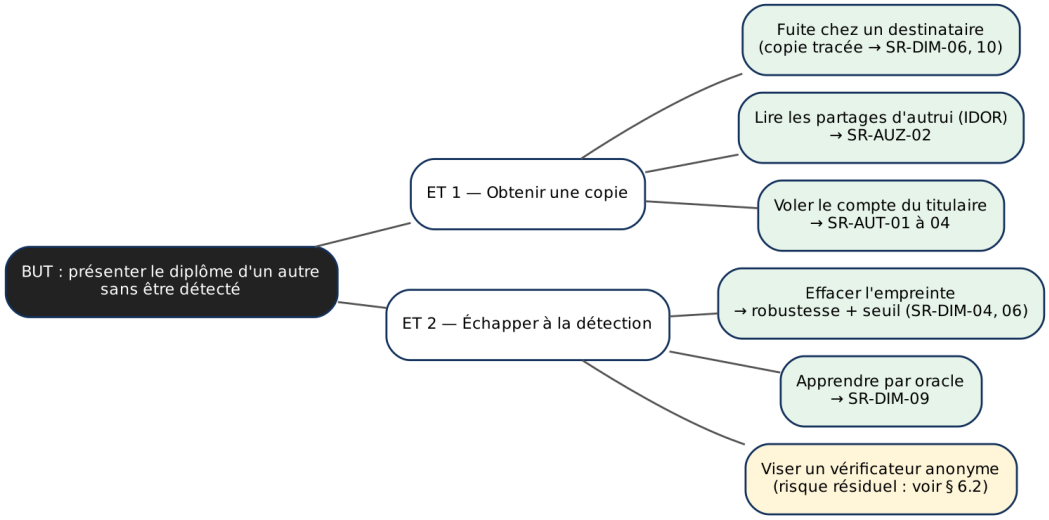


Figure 4 — Arbre d'attaque : présenter le diplôme d'un autre (objectif OS-3)

Enseignement : un imposteur qui vise un vérificateur **anonyme** n'est pas confondu par le contrôle du destinataire, puisque la vérification publique ne révèle pas le destinataire (SR-DIM-08). Le risque

résiduel est réduit par le message de la vérification publique, qui invite le recruteur à demander un **partage EburSeal** nominatif. Il est aussi réduit par l'alerte envoyée au titulaire à chaque vérification de ses copies.

6. SQUARE étape 4 : évaluation des risques

6.1 Analyse STRIDE par composant

STRIDE classe les menaces en six familles : **S**poofing (usurpation), **T**ampering (altération), **R**epudiation (répudiation), **I**nformation disclosure (divulgation), **D**enial of service (déni de service), **E**levation of privilege (élévation de privilège). Chaque menace est rattachée à un cas d'abus, ce qui garantit l'exhaustivité des fiches.

Composant	S	T	R	I	D	E
SPA / PWA	Vol de jeton (CA-05)	XSS modifiant un verdict affiché (CA-08)	—	Cache SW sur poste partagé (CA-05)	—	Script agissant au nom d'un émetteur (CA-08)
API + authentification	Force brute sur un agent (CA-05)	Paramètres altérés, JPQL (CA-08)	Négation d'une validation (CA-10)	Énumération de comptes (CA-05)	Rafales (CA-11)	IDOR, autre établissement (CA-06)
Service d'émission	Faux établissement (CA-04)	Diplôme de complaisance (CA-04)	Validation niée (CA-10)	—	Lots géants (CA-11)	Auto-validation (CA-04)
Moteur de dissimulation	Filigrane imité (CA-01)	Retouche, greffe de marques (CA-02)	—	Sceau lu sans clé (CA-09)	Image bombe (CA-08)	—
Vérification publique	Copie usurpée (CA-03)	Empreinte effacée (CA-07)	—	Oracle, collecte (CA-07, CA-09)	Saturation (CA-11)	—
Base / stockage	—	Réactivation d'un révoqué (CA-10)	—	Vol de base, clés (CA-06)	Saturation	Accès direct par initié (CA-10)
Journaux d'audit	—	Suppression de lignes (CA-10)	Traces effacées (CA-10)	Données personnelles en clair (CA-09)	Saturation des logs	Admin modifiant l'audit (CA-10)

6.2 Matrice des risques

Vraisemblance (V) et impact (I) sont cotés de 1 à 4 ; niveau = **V × I** : ≥ 9 élevé, 5 à 8 moyen, ≤ 4 faible. Tolérance retenue : **aucun risque élevé ne doit subsister** après traitement, et tout risque moyen doit être réduit par au moins une exigence P1 ou P2.

Risque	CA	Scénario	V	I	V×I	Niveau
R-01	CA-01	Faux diplôme accepté par un recruteur	3	4	12	**Élevé**
R-02	CA-02	Diplôme authentique retouché non détecté	3	4	12	**Élevé**
R-03	CA-03	Usurpation du diplôme d'autrui non détectée	3	3	9	**Élevé**
R-04	CA-04	Diplôme de complaisance émis par un initié	2	4	8	**Moyen**
R-05	CA-05	Prise de contrôle d'un compte (agent ou titulaire)	3	4	12	**Élevé**
R-06	CA-06	Accès aux diplômes, partages ou dossiers d'autrui	3	3	9	**Élevé**
R-07	CA-07	Empreinte neutralisée par attaque oracle	2	3	6	**Moyen**
R-08	CA-08	Fichier piégé ou injection	3	3	9	**Élevé**
R-09	CA-09	Collecte massive de données personnelles	2	3	6	**Moyen**
R-10	CA-10	Répudiation d'une émission / altération des journaux	2	3	6	**Moyen**
R-11	CA-11	Indisponibilité de la vérification	3	2	6	**Moyen**

V \ I	1 — mineur	2 — modéré	3 — grave	4 — critique
4				
3		R-11	R-03, R-06, R-08	R-01, R-02, R-05
2			R-07, R-09, R-10	R-04
1				

6 risques sont **élevés** (R-01, R-02, R-03, R-05, R-06, R-08) : les trois fraudes métier, la prise de contrôle de compte, l'accès aux ressources d'autrui et les fichiers piégés. Ils donnent le poids le plus

fort au critère « risque couvert » dans la priorisation (§ 9). R-04 (diplôme de complaisance) n'est « que » moyen en vraisemblance, mais son impact est critique. C'est pourquoi il bénéficie d'exigences P1 dédiées (double validation, MFA des émetteurs).

7. SQUARE étape 5 : techniques d'élicitation retenues

SQUARE demande de choisir les techniques selon les objectifs, l'expertise des participants, le niveau de sécurité visé et le rapport coût/bénéfice. Les participants sont le binôme (parties prenantes, ingénieur des exigences, expert sécurité) et l'encadrant (rôle de client).

Technique	Usage	Justification (coût / bénéfice)
Brainstorming et tableau blanc (binôme)	Cas d'abus, récits d'abus	Technique recommandée par le cours pour les cas d'abus ; coût nul ; adaptée à 2 participants
Analyse des cas d'utilisation	Point de départ (§ 3)	Première action de l'élicitation selon le cours
Analyse de cas réels de fraude	Réalisme des mal-acteurs	Affaires de faux diplômes rapportées par la presse ivoirienne : faux complets, usurpations, complicités internes
Modélisation des menaces (STRIDE, arbres d'attaque)	Exhaustivité	Garantit qu'aucune famille de menace n'est oubliée sur un composant
Checklists (OWASP Top 10 2025, ASVS 5.0 niveau 2)	Contrôle de couverture	Rattrape les exigences omises (faiblesse de SQUARE à l'élicitation)
Revue documentaire	Security drivers	Énoncé, cours, loi n° 2013-450, RGPD, RFC
Entretien avec l'encadrant (client)	Validation du périmètre	À mener en séance : périmètre binôme et niveau de détail attendus ; retours intégrés en v1.1

8. SQUARE étapes 6–7 : exigences de sécurité élicitées et catégorisées

8.1 Principes de rédaction

Chaque exigence respecte les critères **SMART** du cours : **S**pécifique (algorithme, seuil, endpoint nommés), **M**esurable (méthode de vérification indiquée), **A**ctionnable, **R**éaliste (outillage Jakarta EE / WildFly disponible) et **T**emporellement priorisée (P1/P2/P3, chapitre du cours). Elles sont classées dans les deux catégories du cours :

- **exigences de sécurité fonctionnelles**, liées au métier : AUT, AUZ, CON, INT, NRP, DIM, LOG, ERR, DIS ;
- **directives de sécurité (security drivers)**, issues de lois, normes et politiques : loi n° 2013-450 et RGPD (PRV), OWASP ASVS niveau 2 (référence transverse), pratiques imposées par l'énoncé et le cours (TST, DEP).

L'étape 7 de SQUARE distingue aussi le **niveau** (système, logiciel, processus) et sépare les vraies exigences des simples contraintes :

Code	Catégorie	Chapitre du cours	Niveau	Nb
AUT	Identification & authentification	Ch. 4	Logiciel	9
AUZ	Autorisation (contrôle d'accès)	Ch. 4	Logiciel	7
CON	Confidentialité	Ch. 3	Logiciel	5
INT	Intégrité & validation des données	Ch. 3	Logiciel	7
NRP	Non-répudiation	Ch. 3–4	Logiciel	5
DIM	Sécurité des services de dissimulation	Ch. 2–3	Logiciel (métier)	10
PRV	Informations privées (loi n° 2013-450, RGPD)	Ch. 4	Logiciel + organisation	5
LOG	Journalisation, audit & détection d'intrusion	Ch. 5	Logiciel	4
ERR	Gestion des erreurs & conditions exceptionnelles	Ch. 5	Logiciel	3
DIS	Résilience & disponibilité	Ch. 3 / 7	Système	5
TST	Tests de sécurité	Ch. 6	Processus	6
DEP	Déploiement & maintenance	Ch. 7	Système + processus	5
	Total			**71**

> **Contraintes (non-exigences)** — le socle Jakarta EE 11 / WildFly 42 / Java 25 et le type d'application PWA/SPA, imposés par l'énoncé, encadrent les exigences sans en être.

8.2 Identification & authentification (AUT) — Ch. 4

Protègent l'identité des acteurs, en priorité celle des émetteurs : un compte d'agent volé permet d'émettre des diplômes (OS-5, CA-05).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-AUT-01	Le mot de passe comporte **au moins 12 caractères** (jusqu'à 128), sans règle de composition imposée, et est refusé s'il figure dans une liste de 100 000 mots de passe compromis.	CA-05	**P1**	Test d'API : « Password123! » refusé	A07 V6
SR-AUT-02	Les mots de passe sont hachés avec **Argon2id** (m = 19 Mio, t = 2, p = 1), sel aléatoire de 16 octets par compte ; aucun mot de passe n'est stocké ni journalisé en clair.	CA-05	**P1**	Revue de code + inspection de la base	A04 V6, V11
SR-AUT-03	Le second facteur **TOTP** (RFC 6238, fenêtre ±1 pas de 30 s) est **obligatoire** pour les rôles Agent émetteur, Responsable émetteur, Administrateur et Auditeur, et proposé aux autres ; un code n'est accepté qu'une fois.	CA-04, CA-05	**P1**	Test : connexion d'un agent sans TOTP refusée ; rejeu refusé	A07 V6

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-AUT-04	Après **5 échecs** de connexion sur un compte en 15 min, chaque tentative est retardée de façon exponentielle (jusqu'à 15 min) ; l'endpoint de connexion est limité à **20 requêtes/min par IP**.	CA-05	**P1**	Test automatisé de 30 tentatives → 429 et délai mesuré	A07 V6
SR-AUT-05	Les réponses de connexion, d'activation et de réinitialisation sont **identiques** (message et temps de réponse ±50 ms) que le compte existe ou non.	CA-05, CA-09	**P2**	Test d'API : e-mail existant / inexistant	A07 V6
SR-AUT-06	Les jetons d'activation et de réinitialisation font 128 bits aléatoires, sont stockés **hachés**, à usage unique, et expirent (72 h activation, 15 min réinitialisation) ; une réinitialisation invalide toutes les sessions.	CA-05	**P2**	Test : réutilisation du lien → refus	A07 V6
SR-AUT-07	Le jeton d'accès est un JWT signé **ES256**, valide **10 min**, conservé uniquement en mémoire dans la SPA ; le jeton de rafraîchissement (8 h, rotatif, révocable) est un cookie **HttpOnly, Secure, SameSite=Strict**.	CA-05	**P1**	Inspection du navigateur : aucun jeton dans localStorage/sessionStorage	A07 V7, V9
SR-AUT-08	Les opérations sensibles (valider une émission, révoquer, changer de mot de passe ou d'e-mail, désactiver le MFA, changer un rôle) exigent une **ré-authentification** de moins de 5 min.	CA-04, CA-05	**P1**	Test d'API avec authentification ancienne → 403	A07 V6, V7
SR-AUT-09	La déconnexion et la suspension d'un compte **révoquent** immédiatement le jeton de rafraîchissement ; un jeton d'accès révoqué est refusé au plus tard à son expiration (10 min).	CA-05	**P2**	Test : refresh après logout → 401	A07 V7

8.3 Autorisation (contrôle d'accès) (AUZ) — Ch. 4

Garantissent que chaque acteur n'agit que sur ce qui lui revient, et qu'aucune émission ne dépend d'une seule personne (OS-4, CA-04, CA-06).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-AUZ-01	Le contrôle d'accès est **refusé par défaut** : chaque ressource Jakarta REST déclare explicitement ses rôles (@RolesAllowed / @PermitAll / @DenyAll) ; un test fait échouer le build sinon.	CA-06	**P1**	Test d'architecture en CI (déjà en place : AccessControlDeclarationTest)	A01 V8
SR-AUZ-02	Tout accès à un diplôme, une copie, un partage ou un dossier reçu vérifie **côté serveur** l'appartenance (titulaire, établissement émetteur, organisation destinataire) ; sinon la réponse est **404**.	CA-06	**P1**	Tests d'API croisés entre comptes sur chaque endpoint	A01 V8
SR-AUZ-03	**Double validation** : un diplôme n'est émis qu'après validation par un Responsable émetteur **différent** de l'agent qui l'a préparé ; la même règle s'applique aux lots.	CA-04	**P1**	Test : auto-validation par le préparateur → 403	A01, A06 V8, V2
SR-AUZ-04	Un agent ou responsable n'agit que sur **son** établissement, et uniquement si celui-ci a été validé par l'Administrateur.	CA-04, CA-06	**P1**	Test d'API : émission pour un autre établissement → 404	A01 V8
SR-AUZ-05	L'Administrateur ne dispose **d'aucun endpoint** permettant de créer, modifier, valider ou réactiver un diplôme ; l'Auditeur a un accès en lecture seule aux journaux, que personne ne peut modifier via l'application.	CA-04, CA-10	**P2**	Revue de la matrice rôles × endpoints + tests d'API	A01, A09 V8, V16
SR-AUZ-06	Les identifiants exposés sont des **UUID v4** ; leur imprévisibilité est une défense en profondeur et ne remplace jamais SR-AUZ-02.	CA-06	**P3**	Revue de code	A01 V8
SR-AUZ-07	Des **quotas** sont appliqués côté serveur : 500 émissions/jour par établissement, 200 vérifications/jour par vérificateur, 30 partages actifs par diplôme.	CA-04, CA-11	**P2**	Tests de dépassement → 429	A06 V2

8.4 Confidentialité (CON) — Ch. 3

Protègent les clés, les documents et la table des partages ; les clés ne quittent jamais le serveur (CA-01, CA-03, CA-06).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-CON-01	Toutes les communications utilisent **TLS 1.3** (TLS 1.2 toléré avec suites AEAD) ; HTTP redirige vers HTTPS (déjà en place) et l'en-tête **HSTS** (max-age 1 an) est envoyé.	CA-05	**P1**	Scan testssl.sh : note A minimum	A04 V12
SR-CON-02	Les documents (visuels, diplômes émis, copies) sont **chiffrés au repos** en AES-256-GCM avec une clé de données par établissement, elle-même chiffrée par une clé maître stockée dans le **credential store Elytron**.	CA-06	**P2**	Inspection du stockage : fichiers illisibles sans la clé	A04 V11, V14
SR-CON-03	Les clés privées de signature et les clés de filigrane des établissements, la clé de position du sceau et la table des partages sont chiffrées en base avec la même hiérarchie de clés ; elles ne quittent jamais le serveur.	CA-01, CA-03	**P1**	Revue de code + inspection de la base	A04 V11, V14
SR-CON-04	Le contenu du sceau caché est **chiffré** (AES-256-GCM) avant insertion : sans la clé, il est indistinguable de données aléatoires.	CA-02, CA-09	**P3**	Test statistique d'entropie sur le sceau extrait sans clé	A04 V11
SR-CON-05	Le Service Worker ne met en cache **que les ressources statiques** ; les réponses de /api/** sont en **NetworkOnly** (déjà configuré) et portent **Cache-Control: no-store**.	CA-05	**P2**	Test hors ligne après connexion → aucune donnée privée	A02 V3, V14

8.5 Intégrité & validation des données (INT) — Ch. 3

Empêchent l'injection de contenu malveillant, en particulier par les PDF déposés (CA-08).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-INT-01	Un fichier déposé n'est accepté que si sa **signature binaire** est PDF, PNG ou JPEG, s'il fait ≤ **10 Mo**, ≤ **1 page** (PDF) et ≤ **7000 × 7000 px** (vérifié **avant** décodage), et s'il se décode entièrement.	CA-08, CA-11	**P1**	Jeu de tests : polyglotte, bombe d'image, faux MIME → rejet	A05, A06 V5
SR-INT-02	Les PDF déposés sont **rastérisés** à 300 dpi : JavaScript, formulaires, pièces jointes et liens du fichier d'origine ne sont jamais conservés ni servis ; le diplôme émis est un PDF reconstruit par la plateforme.	CA-08	**P1**	Test : PDF avec JavaScript → document émis sans contenu actif	A05, A08 V5
SR-INT-03	Chaque DTO d'entrée est validé par **Jakarta Validation** (types, longueurs, formats en liste blanche, dates cohérentes) ; toute requête non conforme est rejetée (400) avant traitement.	CA-08	**P1**	Tests d'API avec valeurs hors bornes	A05 V2
SR-INT-04	L'accès aux données se fait uniquement par **requêtes paramétrées** (Jakarta Data / JPA) ; toute concaténation dans du JPQL/SQL est interdite et détectée par le SAST.	CA-08	**P1**	Règle Semgrep / FindSecBugs bloquante	A05 V1
SR-INT-05	La SPA n'injecte jamais de HTML non maîtrisé ; une **CSP** stricte est envoyée : default-src 'self' ; script-src 'self' ; object-src 'none' ; frame-ancestors 'none' ; base-uri 'none'.	CA-05, CA-08	**P1**	Scan ZAP + charge utile XSS dans un nom	A05 V3
SR-INT-06	L'endpoint de rafraîchissement, seul à s'appuyer sur un cookie, exige un **jeton anti-CSRF** (double soumission) et vérifie l'en-tête Origin.	CA-05	**P2**	Test : requête intersite forgée → 403	A01 V3
SR-INT-07	Les dépendances sont figées (pom.xml, package-lock.json) et toute ressource tierce éventuelle est chargée avec **Subresource Integrity**.	Chaîne d'approvisionnement	**P2**	Revue de la CI et des fichiers de verrouillage	A03, A08 V15

8.6 Non-répudiation (NRP) — Ch. 3–4

Rendent chaque émission, révocation et vérification prouvable (OS-7, CA-10).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-NRP-01	Chaque émission produit un **certificat signé Ed25519** par la clé de l'établissement : SHA-256 du document, données officielles, identifiants du préparateur et du valideur, horodatage UTC.	CA-01, CA-10	**P1**	Vérification de signature hors ligne	A08 V11
SR-NRP-02	Chaque **révocation** est signée par le Responsable (motif, date) et rendue visible à toute vérification ultérieure ; une révocation est irréversible (on réémet un nouveau diplôme).	CA-04, CA-10	**P1**	Test : réactivation d'un diplôme révoqué impossible	A08 V11, V16
SR-NRP-03	Le journal d'audit est **chaîné** : chaque entrée contient le SHA-256 de la précédente ; un contrôle quotidien vérifie la chaîne et lève une alerte en cas de rupture.	CA-10	**P1**	Test : modification manuelle d'une ligne → alerte	A09 V16
SR-NRP-04	Chaque vérification produit un **rapport signé** par la plateforme (date, verdict, identifiant de copie, vérificateur s'il est authentifié).	CA-03, CA-10	**P3**	Vérification de la signature du rapport	A09 V16
SR-NRP-05	Les serveurs sont synchronisés par **NTP** ; tous les horodatages sont en UTC (ISO 8601).	CA-10	**P3**	Revue de configuration	A09 V16

8.7 Sécurité des services de dissimulation (DIM) — Ch. 2–3

Exigences propres au métier : elles protègent le filigrane, le sceau et l'empreinte, et fixent la règle du verdict (OS-1, OS-2, OS-3).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-DIM-01	Les trois couches (filigrane, sceau, empreinte) occupent des **ensembles disjoints de blocs DCT 8×8**, choisis par un générateur pseudo-aléatoire initialisé par une clé secrète ; l'insertion privilégie les blocs texturés (masquage perceptuel).	CA-01, CA-02, CA-07	**P2**	Test : chaque couche extraite sans erreur en présence des deux autres	A06 V11
SR-DIM-02	Le filigrane est généré avec une **clé secrète propre à chaque établissement** : impossible de produire un filigrane valide au nom d'un établissement sans sa clé.	CA-01	**P1**	Test : détection avec la clé d'un autre établissement → négatif	A04 V11
SR-DIM-03	Le sceau contient les données officielles, l'identifiant du diplôme et de l'établissement, **signés Ed25519** puis chiffrés, et protégés par un code correcteur ; une signature invalide rend le document « non authentique ».	CA-02	**P1**	Test : modification d'un octet du sceau → signature invalide	A08 V11
SR-DIM-04	Seuils de qualité : **PSNR ≥ 40 dB** pour l'ensemble des marques ; filigrane, sceau et empreinte lisibles après **JPEG qualité 75** et **redimensionnement à 75 %** (seuils à confirmer par le prototype J2).	CA-01, CA-02, CA-07	**P1**	Banc de test sur 50 diplômes de référence	A06 V2
SR-DIM-05	Verdict de vérification : **« authentique »** seulement si filigrane détecté ET sceau à signature valide ET statut non révoqué ET (si disponible) concordance avec le registre ; **« indéterminé »** si une marque est illisible ; sinon **« non authentique »**.	CA-01, CA-02, CA-07	**P1**	Tests de décision sur une matrice de cas	A06, A10 V2
SR-DIM-06	Les codes d'empreinte sont des valeurs **aléatoires de 64 bits**, sans lien calculable avec le titulaire ou le destinataire, protégées par un code correcteur ; aucune attribution n'est rendue sous un **seuil de confiance** défini (sinon « indéterminé »).	CA-03, CA-07	**P2**	Tests de robustesse JPEG Q75 + taux de faux positifs nul sur le banc	A04, A06 V11
SR-DIM-07	Aucun fichier sans empreinte ne sort de la plateforme : téléchargement du titulaire et partages produisent toujours une copie empreintée ; l'original n'est jamais servi.	CA-03	**P1**	Test : tous les endpoints de téléchargement renvoient une copie empreintée	A01 V8
SR-DIM-08	La vérification publique **ne révèle jamais** le destinataire d'une copie (« copie partagée — destinataire non divulgué ») ; seuls le titulaire et l'organisation destinataire le voient.	CA-03, CA-09	**P2**	Test d'API anonyme sur une copie partagée	A01 V8, V14

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-DIM-09	La vérification publique est limitée à **10 requêtes/heure par IP** et répond par un verdict **sans score** ni détail de corrélation, pour empêcher l'attaque par oracle.	CA-07, CA-09	**P1**	Test : 11 requêtes → 429 ; revue du format de réponse	A06 V2, V4
SR-DIM-10	Une copie vérifiée par une organisation authentifiée qui n'en est pas destinataire, ou après expiration ou révocation du partage, déclenche un avertissement explicite et une **notification au titulaire** sous 1 min.	CA-03	**P1**	Scénario de test « copie hors contexte »	A06 V2

8.8 Informations privées (loi n° 2013-450, RGPD) (PRV) — Ch. 4

Directives issues de la loi n° 2013-450 et du RGPD : minimisation, absence de recherche publique, transparence envers le titulaire (OS-6).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-PRV-01	Seules les données nécessaires sont collectées (**minimisation**) : nom, prénoms, date de naissance, données du diplôme, e-mail ; les métadonnées EXIF/GPS des fichiers sont supprimées.	Loi n° 2013-450, RGPD	**P2**	Revue du modèle de données + exiftool	A04 V14
SR-PRV-02	Il n'existe **aucune recherche** publique de diplôme par nom, date de naissance ou numéro : la vérification part toujours du document lui-même.	CA-09	**P1**	Revue de l'API : aucun endpoint de recherche public	A01 V8, V14
SR-PRV-03	Les journaux ne contiennent **jamais** de mot de passe, jeton, secret TOTP, clé ni date de naissance ; les personnes y sont désignées par leur identifiant interne.	CA-09, Loi n° 2013-450	**P1**	Recherche automatique de motifs sensibles dans les logs de test	A09 V14, V16
SR-PRV-04	Le titulaire consulte l'**historique des vérifications** de ses copies (date, organisation si authentifiée) et peut exporter ses données ; les journaux sont conservés 12 mois.	Loi n° 2013-450, RGPD	**P2**	Test fonctionnel d'export et d'historique	— V14
SR-PRV-05	Avant toute mise en production réelle, le traitement est **déclaré auprès de l'ARTCI** (autorité ivoirienne de protection des données) et une mention d'information est présentée aux titulaires.	Loi n° 2013-450	**P3**	Dossier de conformité archivé dans docs/	— —

8.9 Journalisation, audit & détection d'intrusion (LOG) — Ch. 5

Permettent de détecter les fraudes internes et de reconstituer les faits (OS-7) ; détaillées au chapitre 5.

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-LOG-01	Sont journalisés : connexions réussies/échouées, MFA, préparations, validations, émissions, révocations, partages, vérifications, refus d'accès, fichiers rejetés, actions d'administration.	CA-04, CA-06, CA-10	**P1**	Test : chaque événement produit une entrée	A09 V16
SR-LOG-02	Chaque entrée est en **JSON** (horodatage UTC, corrélation, acteur, IP, action, ressource, résultat) ; retours à la ligne et caractères de contrôle neutralisés (anti-injection de logs).	CA-10	**P2**	Test : nom avec \r\n → entrée unique	A09 V16
SR-LOG-03	Des **alertes** sont levées vers l'Auditeur : ≥ 10 échecs de connexion sur un compte en 5 min ; émissions d'un établissement > 3 fois sa moyenne quotidienne ; ≥ 20 refus d'accès d'un même compte en 10 min ; rupture de la chaîne d'audit.	CA-04, CA-05, CA-06	**P1**	Scénarios simulés → alerte visible	A09 V16
SR-LOG-04	Les journaux d'audit sont écrits sur un stockage distinct, en ajout seul, et sauvegardés quotidiennement.	CA-10	**P2**	Revue de déploiement	A09 V16

8.10 Gestion des erreurs & conditions exceptionnelles (ERR) — Ch. 5

Couvrent la catégorie A10:2025 : ne rien révéler et échouer en mode sûr, un « indéterminé » ne devient jamais « authentique ».

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-ERR-01	Un **ExceptionMapper** global renvoie des erreurs au format **RFC 9457** (application/problem+json), message générique et identifiant de corrélation, sans trace de pile ni version.	CA-08	**P2**	Test : erreur 500 provoquée → corps générique	A10, A02 V16
SR-ERR-02	Le système échoue en **mode sûr** : toute exception pendant une vérification de droits, de signature ou d'extraction aboutit à un refus ou à « indéterminé », jamais à « authentique ».	CA-01, CA-06, CA-07	**P1**	Tests d'injection de fautes	A10 V16
SR-ERR-03	Les conditions exceptionnelles métier (document illisible, page multiple, capacité insuffisante, délai dépassé, quota atteint) produisent un message explicite et un **état cohérent** (transaction annulée, aucun fichier partiel).	CA-08, CA-11	**P2**	Tests unitaires des cas limites	A10 V16

8.11 Résilience & disponibilité (DIS) — Ch. 3 / 7

Garantissent la disponibilité de la vérification face aux abus (OS-8, CA-11).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-DIS-01	Les opérations coûteuses (émission, extraction, vérification) sont limitées à **10 par minute et par compte** en plus des quotas journaliers.	CA-11	**P1**	Test de charge : 11e requête → 429	A06 V2
SR-DIS-02	Les traitements d'image s'exécutent dans un **ManagedExecutorService** (Jakarta Concurrency) à file bornée, avec un délai maximal de **30 s** par document ; les lots sont traités en tâche de fond.	CA-11	**P2**	Test : document lourd → arrêt à 30 s	A06 V15
SR-DIS-03	WildFly limite la taille des requêtes (max-post-size 12 Mo, 50 Mo pour les lots) et le nombre de connexions simultanées par client.	CA-08, CA-11	**P2**	Test : envoi de 20 Mo → 413	A02 V13
SR-DIS-04	Base de données, documents chiffrés et clés sont **sauvegardés quotidiennement** ; une restauration est testée à chaque release (RPO 24 h, RTO 4 h).	Disponibilité	**P2**	Exercice de restauration documenté	— V14
SR-DIS-05	Des sondes de santé (live / ready) permettent le redémarrage automatique du conteneur applicatif.	CA-11	**P3**	Test : arrêt de la base → ready = DOWN	— V13

8.12 Tests de sécurité (TST) — Ch. 6

Exigences de processus : elles vérifient en continu que les autres exigences sont respectées (chapitre 6).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-TST-01	Chaque pull request déclenche une analyse **SAST** (SpotBugs + FindSecBugs, Semgrep) ; le merge est bloqué en présence d'une alerte de sévérité haute.	Processus	**P2**	Pipeline GitHub Actions	A06 V15
SR-TST-02	Une analyse de composition (**SCA** : OWASP Dependency-Check, npm audit, Dependabot) bloque le build pour toute vulnérabilité CVSS ≥ 7.	Chaîne d'approvisionnement	**P1**	Pipeline GitHub Actions	A03 V15
SR-TST-03	Une analyse **DAST** (OWASP ZAP) est exécutée sur l'environnement de recette avant chaque release ; aucune alerte haute ne doit subsister.	Processus	**P2**	Rapport ZAP archivé dans docs/	A02, A05 —
SR-TST-04	Chaque cas d'abus (CA-01 à CA-11) est couvert par **au moins un test automatisé** qui démontre l'échec de l'attaque.	Tous les CA	**P1**	Matrice de traçabilité CA → test	A06 —
SR-TST-05	Une recherche de **secrets** (gitleaks) est exécutée à chaque push ; tout secret détecté bloque le pipeline.	Chaîne d'approvisionnement	**P2**	Pipeline GitHub Actions	A02 V13

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-TST-06	Un **banc de robustesse** automatisé (recompression JPEG, redimensionnement, recadrage léger, conversion PDF ↔ image) est exécuté à chaque modification du moteur de dissimulation.	CA-07	**P2**	Rapport du banc en CI	A06 —

8.13 Déploiement & maintenance (DEP) — Ch. 7

Exigences de déploiement et de maintenance : durcissement, secrets, correctifs, rotation des clés (chapitre 7).

ID	Exigence	Origine	Prio	Vérification	OWASP / ASVS
SR-DEP-01	WildFly est **durci** : interface de management liée à 127.0.0.1, aucun compte par défaut, sous-systèmes inutiles retirés, en-têtes Server / X-Powered-By supprimés, exécution non root.	A02	**P1**	Revue de configuration + scan de ports	A02 V13
SR-DEP-02	Aucun secret n'est présent dans le dépôt Git ; ils sont fournis par le credential store Elytron ou des variables d'environnement du conteneur.	A02	**P1**	gitleaks + revue	A02 V13
SR-DEP-03	Les en-têtes de sécurité sont envoyés sur toutes les réponses : HSTS, CSP, X-Content-Type-Options: nosniff, Referrer-Policy: no-referrer, Permissions-Policy restrictive.	CA-05, CA-08	**P2**	Scan securityheaders / ZAP	A02 V3
SR-DEP-04	Les images de conteneur sont minimales, exécutées sans root et analysées (Trivy) avant publication ; aucune vulnérabilité critique tolérée.	Chaîne d'approvisionnement	**P2**	Rapport Trivy en CI	A03 V13
SR-DEP-05	Les dépendances sont mises à jour **au moins une fois par mois** ; un correctif de sécurité critique est déployé sous **7 jours** ; les clés d'établissement sont renouvelables sans invalider les diplômes déjà émis.	Processus	**P2**	Historique Dependabot + procédure de rotation testée	A03 V15, V11

9. SQUARE étape 8 : priorisation (AHP)

Le cours cite trois méthodes de priorisation pour SQUARE : **AHP**, Triage et Win-Win. Nous utilisons l'**AHP** (*Analytic Hierarchy Process*) pour fixer objectivement le **poids des critères**, puis un **triage** en trois classes. L'AHP compare les critères deux à deux sur l'échelle de Saaty (1 = importance égale, 3 = modérément plus important, 5 = nettement plus important).

9.1 Critères et matrice de comparaison

	R — risque couvert	C — obligation	F — facilité	Poids w
Risque couvert (R)	1	3	5	**0.637**
Obligation (C)	1/3	1	3	**0.258**
Facilité (F)	1/5	1/3	1	**0.105**

- **R — risque couvert** : 3 si l'exigence traite un risque élevé, 2 si moyen, 1 si faible ou indirect ;
- **C — obligation** : 3 si imposée par une loi, par le cours ou par l'ASVS niveau 2, 2 si recommandée, 1 si choix de l'équipe ;
- **F — facilité** : 3 si native dans Jakarta EE / WildFly, 2 si quelques jours de travail, 1 si effort important.

Les poids sont obtenus par le vecteur propre principal : $\lambda_{max} = 3.039$, indice de cohérence CI = 0.019, **ratio de cohérence CR = 0.033** (indice aléatoire RI = 0,58 pour n = 3). CR < 0,10 : les jugements sont **cohérents**. Le risque pèse près des deux tiers de la décision : c'est une priorisation **fondée sur le risque**, comme celle que recommande OWASP SAMM (chapitre 1).

9.2 Règle de triage et résultat

Score = $w_R \cdot R + w_C \cdot C + w_F \cdot F$ (entre 1 et 3). **P1** si score ≥ 2,50 (implémentée au chapitre correspondant, bloquante pour la release) ; **P2** si 1,90 ≤ score < 2,50 (implémentée avant la fin du module) ; **P3** sinon (implémentée si le temps le permet, sinon reportée et documentée).

Classe	Nombre	Exigences
P1	37	AUT-01, AUT-02, AUT-03, AUT-04, AUT-07, AUT-08, AUZ-01, AUZ-02, AUZ-03, AUZ-04, CON-01, CON-03, INT-01, INT-02, INT-03, INT-04, INT-05, NRP-01, NRP-02, NRP-03, DIM-02, DIM-03, DIM-04, DIM-05, DIM-07, DIM-09, DIM-10, PRV-02, PRV-03, LOG-01, LOG-03, ERR-02, DIS-01, TST-02, TST-04, DEP-01, DEP-02
P2	28	AUT-05, AUT-06, AUT-09, AUZ-05, AUZ-07, CON-02, CON-05, INT-06, INT-07, DIM-01, DIM-06, DIM-08, PRV-01, PRV-04, LOG-02, LOG-04, ERR-01, ERR-03, DIS-02, DIS-03, DIS-04, TST-01, TST-03, TST-05, TST-06, DEP-03, DEP-04, DEP-05
P3	6	AUZ-06, CON-04, NRP-04, NRP-05, PRV-05, DIS-05

Le détail des notes (R, C, F) et du score de chaque exigence figure dans **docs/exigences.csv**, ce qui permet de rejouer la priorisation à chaque évolution. Une exigence P3 n'est jamais supprimée : elle reste au référentiel avec son statut.

10. SQUARE étape 9 : inspection et traçabilité

10.1 Inspection des exigences

Chaque exigence est relue par le membre du binôme qui ne l'a pas rédigée (revue par les pairs, inspiration Fagan), selon la grille suivante :

Point de contrôle	Question posée	Résultat v1.0
Non-ambiguïté	Deux développeurs l'implémenteraient-ils de la même façon ?	Formulations vagues reprises avec des seuils (ex. « contrôler l'émission » → « valideur différent du préparateur »)
Testabilité	Une méthode de vérification est-elle donnée ?	71/71 exigences avec méthode de vérification
Traçabilité	Est-elle rattachée à un CA, un risque, un actif ou un driver ?	71/71 rattachées (colonne « Origine »)
Non-généricité	Est-elle propre à EburSeal (critère de l'énoncé) ?	Exigences génériques remplacées par des règles métier précises
Absence de mécanisme dans les CS	Les CS décrivent-ils le « quoi » et non le « comment » ?	Conforme : mécanismes uniquement dans les SR
Conflits	Contredit-elle une autre exigence ou un besoin fonctionnel ?	6 conflits identifiés et résolus (ci-dessous)

Conflits détectés et décisions

Conflit	Décision et justification
Vérification publique ouverte à tous (BF-VER-01) vs protection des données (OS-6) et anti-oracle	Vérification maintenue, mais **uniquement à partir du document** (SR-PRV-02), limitée à 10/h/IP et sans score (SR-DIM-09)
Détection des copies hors contexte (BF-FP-03) vs confidentialité du destinataire	Le destinataire n'est jamais révélé publiquement (SR-DIM-08) ; seuls le titulaire et l'organisation destinataire le voient
Traçage des fuites (fingerprinting) vs minimisation (SR-PRV-01)	La table des partages ne contient que ce qui est nécessaire (destinataire, finalité, dates) et est chiffrée (SR-CON-03)
Fermeture du compte titulaire (BF-CPT-05) vs conservation du registre	Le diplôme reste au registre de l'établissement (obligation de l'émetteur) ; seuls le compte, les partages et l'historique du titulaire sont supprimés
MFA obligatoire pour tous vs ergonomie (OM-4)	MFA **obligatoire** pour émetteurs, administrateur, auditeur ; **proposé** aux titulaires et vérificateurs (SR-AUT-03)
Échec en mode sûr (SR-ERR-02) vs disponibilité (OS-8)	La sécurité prime : en cas de doute, « indéterminé ». La disponibilité est assurée en amont par les quotas et délais maximaux (SR-DIS-01, 02)

10.2 Matrice de traçabilité

La matrice relie chaque menace à ses exigences et au test qui démontre l'échec de l'attaque (SR-TST-04). Elle est complétée à chaque séance avec les liens vers les tests du dépôt.

CA	Risque (niveau)	CS	Exigences P1	Autres exigences	Test d'abus prévu	Ch.
CA-01	R-01 (Élevé)	CS-01	CON-03, NRP-01, DIM-02, DIM-04, DIM-05, ERR-02	DIM-01	AbuseCase01IT	3
CA-02	R-02 (Élevé)	CS-02	DIM-03, DIM-04, DIM-05	CON-04, DIM-01	AbuseCase02IT	3
CA-03	R-03 (Élevé)	CS-03	CON-03, DIM-07, DIM-10	NRP-04, DIM-06, DIM-08	AbuseCase03IT	3
CA-04	R-04 (Moyen)	CS-04	AUT-03, AUT-08, AUZ-03, AUZ-04, NRP-02, LOG-01, LOG-03	AUZ-05, AUZ-07	AbuseCase04IT	4
CA-05	R-05 (Élevé)	CS-05	AUT-01, AUT-02, AUT-03, AUT-04, AUT-07, AUT-08, CON-01, INT-05, LOG-03	AUT-05, AUT-06, AUT-09, CON-05, INT-06, DEP-03	AbuseCase05IT	4
CA-06	R-06 (Élevé)	CS-06	AUZ-01, AUZ-02, AUZ-04, LOG-01, LOG-03, ERR-02	AUZ-06, CON-02	AbuseCase06IT	4

CA	Risque (niveau)	CS	Exigences P1	Autres exigences	Test d'abus prévu	Ch.
CA-07	R-07 (Moyen)	CS-07	DIM-04, DIM-05, DIM-09, ERR-02	DIM-01, DIM-06, TST-06	AbuseCase07IT	3
CA-08	R-08 (Élevé)	CS-08	INT-01, INT-02, INT-03, INT-04, INT-05	ERR-01, ERR-03, DIS-03, DEP-03	AbuseCase08IT	3
CA-09	R-09 (Moyen)	CS-09	DIM-09, PRV-02, PRV-03	AUT-05, CON-04, DIM-08	AbuseCase09IT	4
CA-10	R-10 (Moyen)	CS-10	NRP-01, NRP-02, NRP-03, LOG-01	AUZ-05, NRP-04, NRP-05, LOG-02, LOG-04	AbuseCase10IT	5
CA-11	R-11 (Moyen)	CS-11	INT-01, DIS-01	AUZ-07, ERR-03, DIS-02, DIS-03, DIS-05	AbuseCase11IT	3

10.3 Couverture de l'OWASP Top 10 2025

Contrôle de couverture (checklist de l'étape 5) : chaque catégorie de l'OWASP Top 10 2025 est traitée par au moins une exigence.

Catégorie 2025	Nb	Exigences
A01 — Broken Access Control	10	AUZ-01, AUZ-02, AUZ-03, AUZ-04, AUZ-05, AUZ-06, INT-06, DIM-07, DIM-08, PRV-02
A02 — Security Misconfiguration	8	CON-05, ERR-01, DIS-03, TST-03, TST-05, DEP-01, DEP-02, DEP-03
A03 — Software Supply Chain Failures	4	INT-07, TST-02, DEP-04, DEP-05
A04 — Cryptographic Failures	8	AUT-02, CON-01, CON-02, CON-03, CON-04, DIM-02, DIM-06, PRV-01
A05 — Injection	6	INT-01, INT-02, INT-03, INT-04, INT-05, TST-03
A06 — Insecure Design	14	AUZ-03, AUZ-07, INT-01, DIM-01, DIM-04, DIM-05, DIM-06, DIM-09, DIM-10, DIS-01, DIS-02, TST-01, TST-04, TST-06
A07 — Authentication Failures	8	AUT-01, AUT-03, AUT-04, AUT-05, AUT-06, AUT-07, AUT-08, AUT-09
A08 — Software or Data Integrity Failures	5	INT-02, INT-07, NRP-01, NRP-02, DIM-03
A09 — Security Logging & Alerting Failures	9	AUZ-05, NRP-03, NRP-04, NRP-05, PRV-03, LOG-01, LOG-02, LOG-03, LOG-04
A10 — Mishandling of Exceptional Conditions	4	DIM-05, ERR-01, ERR-02, ERR-03

11. Gestion des exigences (évolution du recueil)

Le cours fait de la **gestion** la quatrième phase de l'IES, avec une erreur à éviter : des exigences non priorisées ou mal planifiées. L'énoncé précise que ce recueil évoluera. Nous appliquons donc le processus suivant :

- **Déclencheur** : nouveau chapitre, nouvelle menace, test en échec, résultat du prototype ou retour de l'encadrant → issue GitHub (modèle security-story) ;
- **Analyse d'impact** : actifs, cas d'abus, autres exigences et tests concernés ; vérification de l'absence de conflit (§ 10.1) ;
- **Mise à jour du référentiel unique** (docs/src/data.py) : ajout, modification ou passage au statut « Obsolète » (une exigence n'est jamais effacée) ;
- **Régénération** des PDF et du CSV (docs/src/build.sh), nouvelle version (1.1, 1.2…) et ligne d'historique ;
- **Revue** par l'autre membre via pull request, puis tag de séance.

Statut	Signification
Proposée	Issue ouverte, pas encore analysée
Spécifiée	Rédigée, inspectée et priorisée (statut de toutes les exigences en v1.0)
Implémentée	Code fusionné sur develop, référencé dans la PR
Vérifiée	Test automatisé vert ; lien vers le test dans la matrice de traçabilité
Obsolète	Remplacée ou sans objet ; conservée pour l'historique avec sa justification

Engagement — les seuils de SR-DIM-04 (PSNR, robustesse) seront confirmés ou ajustés par le prototype du moteur au jalon J2 ; ce sera la première évolution du recueil (v1.1). Les exigences P1 de chaque chapitre doivent passer « Vérifiées » avant le tag de ce chapitre.